Sicurezza dei Sistemi Informativi

01UDUOV

Politecnico di Torino

Prof. Cataldo Basile

A cura degli studenti:
A.A. 2025/26: *Alessandro Annecchini*, *Alessio Giliberti*, *Chiara Mercurio*, *Luca Giacchetta*

Copyright © 2025-2026 Cataldo Basile
Licensed under the Creative Commons Attribution-NonCommercial 3.0 Unported License (the "License"). You may not use this file except in compliance with the License. You may obtain a copy of the License at `http://creativecommons.org/licenses/by-nc/3.0`. Unless required by applicable law or agreed to in writing, software distributed under the License is distributed on an "AS IS" BASIS, WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied. See the License for the specific language governing permissions and limitations under the License.

Indice

1 Introduzione 5

1.1 La sicurezza informatica: motivazioni e dati 5

1.1.1 Alcune definizioni di sicurezza 5
1.1.2 I motivi dell'importanza della sicurezza informatica 6
1.1.3 Insicurezza: le cause profonde 7
1.1.4 Verizon Data Breach Investigation Report 7

1.2 Minacce e problemi di base 10

1.2.1 Problemi tecnologici di base 10
1.2.2 Complessità 10
1.2.3 Altri problemi tecnologici 11

1.3 Attacchi e tecniche 11

1.3.1 Malware 13
1.3.2 Ransomware 14
1.3.3 Industria del Cybercrime 15

1.4 Altri problemi e minacce 15

1.4.1 Alcuni esempi di attacchi riconducibili a errori umani 15
1.4.2 Ingegneria sociale 17
1.4.3 Attacchi famosi 18

1.5 Sicurezza: definizioni 20

1.5.1 Riservatezza 20
1.5.2 Integrità 20
1.5.3 Autenticazione della controparte 21
1.5.4 Autenticazione dei dati 21
1.5.5 Non ripudio 21
1.5.6 Autorizzazione (o controllo degli accessi) 22
1.5.7 Protezione dei dati 22

1.6 Principi di sicurezza 22

1.7 I tre pilastri della sicurezza 23

Todo list

1. Introduzione

Il presente capitolo si propone di illustrare il ruolo centrale della sicurezza informatica nel contesto odierno, analizzandone l'evoluzione storica, le minacce più diffuse e le principali categorie di malware. Successivamente, si esamineranno i fondamenti della difesa informatica, con particolare attenzione ai principi e alle proprietà che ne costituiscono il nucleo concettuale.

In termini generali, *fare sicurezza* significa **portare i rischi a livelli accettabili**, concetto la cui definizione richiede un'attenta contestualizzazione rispetto agli obiettivi organizzativi e alle risorse disponibili.

1.1 La sicurezza informatica: motivazioni e dati

1.1.1 Alcune definizioni di sicurezza

È opportuno innanzitutto chiarire cosa si intenda per **sicurezza informatica**. Nel corso degli anni sono emerse diverse accezioni di questo concetto, ciascuna con specifiche sfumature di significato:

- Una prima definizione, di matrice aziendale, la identifica come:

  > L'insieme dei prodotti, dei servizi, delle regole organizzative e dei comportamenti individuali che proteggono i sistemi informatici di un'azienda.

  Questa prospettiva adotta un approccio pragmatico, sottolineando l'obiettivo di garantire il corretto funzionamento dei sistemi aziendali e la protezione degli asset anche in presenza di minacce provenienti da attori malevoli.
- Una seconda definizione, emersa successivamente, enfatizza invece:

  > Il compito di proteggere le risorse da accessi indesiderati, garantire la riservatezza delle informazioni, assicurare il funzionamento e la disponibilità dei servizi a fronte di eventi imprevedibili (C.I.A. = Confidentiality, Integrity, Availability).

  In questo caso l'attenzione si concentra sulla prevenzione di accessi non autorizzati, sia da parte di attori criminali sia di soggetti concorrenti. Successivamente introduce quella che viene chiamata *CIA triad*, tre concetti essenziali per poter costruire sistemi sicuri. La confidenzialità riguarda la protezione della segretezza dei dati mentre l'integrità indica la necessità di preservare dati e sistemi da modifiche non autorizzate. Viene inoltre introdotto il concetto di disponibilità, aspetto talvolta considerato al confine della sicurezza informatica in senso stretto, ma rilevante nella misura in cui mira a impedire che terzi possano compromettere l'erogazione dei servizi, causando perdite economiche.
- Una terza definizione riprende l'aspetto applicativo della prima e rappresenta la necessità di riportare il mondo informatico e virtuale all'esperienza fisica:

> L'obiettivo è custodire le informazioni con la stessa professionalità ed attenzione con cui ci si prende cura di gioielli o certificati azionari depositati nel caveau. Il sistema informatico è la cassaforte delle nostre informazioni più preziose; la sicurezza informatica è l'equivalente delle serrature, combinazioni e chiavi che servono a proteggerla.

Questa prospettiva evidenzia la sicurezza informatica come trasposizione digitale dei meccanismi di protezione fisica tradizionalmente impiegati per la tutela di beni di valore.

1.1.2 I motivi dell'importanza della sicurezza informatica

La sicurezza informatica è spesso percepita dai vertici aziendali come un investimento privo di ritorno immediato: l'implementazione di misure di protezione non genera profitto diretto e può, al contrario, ridurre la produttività operativa. Tuttavia, un'analisi più approfondita evidenzia tre motivazioni fondamentali che ne giustificano l'essenzialità:

- **Ragioni economiche**: la progressiva digitalizzazione degli asset aziendali ha reso il patrimonio informativo un bene critico da proteggere. Gli istituti finanziari, ad esempio, operano quasi interamente su piattaforme digitali, rendendo evidente la necessità di tutelare tali risorse per prevenire danni economici. Per le organizzazioni, le conseguenze di una compromissione possono manifestarsi in molteplici forme: sottrazione di segreti industriali da parte di concorrenti, danno reputazionale derivante dalla violazione di dati sensibili dei clienti, interruzione prolungata dei servizi con conseguente perdita di ricavi e pagamento di penali per violazione dei *Service Level Agreement*.
- **Ragioni sociali ed etiche**: la sicurezza informatica riveste un ruolo essenziale nella protezione individuale e nella tutela della privacy. La correttezza nella gestione dei dati personali e la prevenzione dello sfruttamento dei dati costituiscono diritti fondamentali che le organizzazioni sono tenute a garantire. Una compromissione può comportare gravi violazioni della riservatezza, esponendo informazioni sensibili degli utenti a utilizzi impropri, furti di identità o discriminazioni.
- **Ragioni di Stato**: la sicurezza informatica rappresenta oggi un elemento strategico per la difesa nazionale. Il contesto attuale è caratterizzato da una *guerra ibrida*, in cui gli Stati organizzano operazioni offensive e difensive attraverso il cyberspazio. A titolo esemplificativo, la Russia conduce campagne periodiche volte a destabilizzare l'Unione Europea[1], prassi storicamente adottata anche dagli Stati Uniti in contesti geopolitici differenti. Analogamente, la Cina avrebbe istituito un dipartimento dedicato all'*offensive security*, con l'obiettivo di acquisire proprietà intellettuale su scala globale, con particolare attenzione al contesto statunitense.

Nel seguito del corso ci si concentrerà prevalentemente sulle ragioni economiche, in quanto più facilmente inquadrabili da una prospettiva ingegneristica.

In passato, le piccole e medie imprese ritenevano di non rappresentare obiettivi di interesse per gli attaccanti, limitando di conseguenza gli investimenti in sicurezza informatica. Tuttavia, è oggi evidente che la probabilità di subire un attacco è estremamente elevata per qualsiasi organizzazione, indipendentemente dalle dimensioni. Gli attori criminali adottano infatti strategie di tipo *pesca a strascico*, orientandosi non verso singoli obiettivi di alto valore, ma verso un elevato numero di bersagli con difese meno strutturate, massimizzando il profitto attraverso la numerosità delle compromissioni. Questo è reso possibile da una grande abilità nell'automazione nello sfruttamento degli attacchi e a una rete efficiente nel trasformare gli effetti degli attacchi (dati confidenziali, risorse computazionali, accessi non autorizzati) in valore. Parallelamente, le grandi organizzazioni risultano vulnerabili ad attacchi più sofisticati mirati alla loro catena di fornitura (*supply chain attack*). Compromettendo fornitori, partner commerciali o componenti software di terze parti

[1] Consiglio dell'Unione Europea, 2025

utilizzati dall'azienda target, gli attaccanti possono ottenere accesso indiretto a sistemi altrimenti ben protetti. Queste tipologie di attacchi, particolarmente insidiosi, sfruttano le relazioni di fiducia tra organizzazioni e la complessità delle moderne catene di approvvigionamento digitali.

Nel complesso, possiamo dedurre che gli investimenti nella cybersecurity sono incrementati notevolmente nell'ultimo periodo perché, nella maggior parte dei casi, il danno economico conseguente a un attacco supera di gran lunga il costo degli investimenti preventivi in sicurezza.

Le principali conseguenze economiche non si limitano ai danni **diretti** (ad esempio, trasferimenti fraudolenti di fondi), ma si articolano prevalentemente in impatti **indiretti**:

- Deprezzamento del valore azionario;
- Sanzioni, es. quelle comminate dal garante della privacy in caso di violazione delle legge europea sulla privacy (GDPR);
- **Costi di ripristino**, le spese necessarie per riportare il sistema allo stato operativo originale e implementare misure correttive volte a prevenire ulteriori compromissioni;
- **Perdita di produzione**, mancati guadagni dovuti a interruzioni o rallentamenti dei processi produttivi, mancata acquisizione di contratti;
- **Perdita di clienti e commesse**: mancati guadagni dovuti all'erosione della base clienti dovuta alla perdita di fiducia conseguente all'incidente (es. danno reputazionale).

1.1.3 Insicurezza: le cause profonde

In seguito al primo attacco informatico di rilevanza pubblica negli Stati Uniti, all'inizio degli anni 2000, l'amministrazione Clinton commissionò un documento analitico volto a identificare le cause profonde dell'insicurezza informatica. Le principali criticità individuate furono le seguenti:

- Le tecnologie di attacco evolvono rapidamente e secondo un modello *open-source*, risultando ampiamente accessibili e facilmente adattabili;
- Le tecniche e metodologie di difesa adottano un approccio reattivo. Ad esempio, una volta scoperta una vulnerabilità, si può proteggere un sistema che espone tale vulnerabilità solo dopo la pubblicazione di patch di sicurezza. Questo implica una condizione strutturale di ritardo, da parte dei difensori, fino all'implementazione delle correzioni, configurando una dinamica in cui i difensori inseguono costantemente gli attaccanti;
- Milioni di sistemi caratterizzati da livelli di sicurezza ridotti o assenti sono connessi a Internet, ad esempio i sistemi legacy, e rispetto al 2000, data della relazione, dovremmo includere anche i dispositivi IoT (Internet of Things);
- La rapida diffusione di Internet ha reso necessaria l'assunzione di personale privo di competenze specifiche in materia di sicurezza informatica;
- Lo sviluppo di software complessi è spesso affidato a programmatori senza formazione in pratiche di programmazione sicura;
- Gli attacchi e gli strumenti impiegati trascendono i confini geografici e le giurisdizioni nazionali;
- La complessità delle investigazioni sui crimini informatici, unitamente alle problematiche legate al diritto internazionale, rende improbabile il perseguimento effettivo dei responsabili.

L'analisi condotta oltre due decenni fa mantiene piena attualità e, per certi aspetti, descrive una situazione aggravata dall'incremento esponenziale del numero di dispositivi connessi, dalla complessità dei servizi erogati e dall'efficienza delle organizzazioni criminali che investono in cybercrime.

1.1.4 Verizon Data Breach Investigation Report

Diverse organizzazioni pubblicano periodicamente report di cybersecurity per scopi strategici e analitici. Tra queste, Verizon[2], azienda di telecomunicazioni statunitense, redige annualmente

[2] Verizion, 2025

un'analisi degli incidenti di sicurezza **dichiarati** e collezionati dal 1 novembre al 31 ottobre dell'anno precedente, conducendo indagini statistiche scientificamente rilevanti. Le informazioni che seguono sono di carattere generale e non si riferiscono ad una versione specifica del report.

Costi

I grafici contenuti nei report illustrano i costi diretti e indiretti derivanti dagli attacchi dichiarati, suddivisi per categoria di attacco. Dall'analisi emerge la perdita mediana e massima subita dalle organizzazioni per ciascuna categoria di attacco. Una sezione del report può inoltre includere i costi forensi, relativi alle analisi necessarie per determinare le responsabilità dell'incidente, al fine di avviare eventuali azioni legali volte al recupero parziale dei danni. Inoltre, i report indicano che molte aziende non hanno subito perdite a causa degli attacchi. Questa situazione, seppure probabile, potrebbe essere giustificata dal fatto che le aziende tendono a mantenere segrete le conseguenze degli attacchi o a minimizzarle, per evitare gli effetti collaterali (es. perdita di reputazione, perdita di valore delle azioni).

Come esempio, si riporta che negli ultimi anni, tra le tipologie più rilevanti figurano il BEC[3], il CDB[4] e il Ransomware.

Principali attori

Il report classifica le principali categorie di attaccanti, tra cui organizzazioni criminali strutturate, governi e minacce interne all'organizzazione, analizzandone le motivazioni dominanti, quali il profitto economico e l'acquisizione di informazioni riservate per finalità di spionaggio.

Dai report degli ultimi anni emerge inoltre la progressiva evoluzione del crimine informatico verso un modello industriale organizzato secondo una logica di *supply chain*: la produzione e distribuzione di malware, l'erogazione di servizi DDoS su commissione, il commercio di credenziali compromesse, la gestione di strutture di supporto fraudolente e le operazioni di riciclaggio costituiscono segmenti distinti ma interconnessi di un ecosistema criminale altamente specializzato. Tale frammentazione delle competenze ottimizza l'efficacia operativa delle campagne malevole, massimizzando i profitti dei criminali e rendendo al contempo estremamente complesso il tracciamento delle responsabilità individuali e l'azione giudiziaria contro i perpetratori.

Motivazione degli attaccanti esterni

I grafici in questione evidenziano le differenze nelle motivazioni degli attaccanti in funzione delle dimensioni dell'organizzazione bersaglio.

I report più recenti fanno emergere un pattern distintivo: gli attacchi diretti verso grandi organizzazioni sono frequentemente motivati da protesta o curiosità. Nel primo caso, gruppi hacktivisti o individui ideologicamente orientati scelgono obiettivi ad alta visibilità per amplificare il messaggio politico o sociale, mirando a danneggiare la reputazione dell'organizzazione o a rendere pubbliche pratiche ritenute scorrette. Nel secondo caso, attaccanti mossi da curiosità tecnica o dalla ricerca di prestigio nella comunità hacker tendono a sfidare i sistemi di difesa più sofisticati, considerando la compromissione di grandi aziende come una dimostrazione di abilità tecnica superiore. Al contrario, gli attacchi rivolti alle piccole e medie imprese sono quasi univocamente lanciati per motivazioni di natura economica.

[3] Business Email Compromise (BEC): attacco informatico sofisticato in cui un attaccante compromette o falsifica account di posta elettronica aziendali per indurre vittime a effettuare trasferimenti di fondi o a divulgare informazioni sensibili. Tipicamente l'attaccante si finge un dirigente, un fornitore o un partner commerciale fidato.

[4] Computer Data Breach (CDB): violazione della sicurezza che comporta l'accesso non autorizzato, la copia, la trasmissione o l'utilizzo di dati riservati. Include incidenti quali furto di credenziali, esfiltrazione di informazioni sensibili e accessi non autorizzati a database aziendali.

Access vector

L'*access vector* descrive da dove e con quali mezzi un attaccante può operare e descrive di solito anche il livello di privilegi necessario per condurre l'attacco. Può essere considerato il punto di partenza di un attacco.

L'analisi dei dati più recenti mostra l'evoluzione dei vettori di accesso utilizzati negli attacchi. Mentre l'abuso delle credenziali è in diminuzione, probabilmente grazie all'adozione dell'autenticazione a più fattori (MFA) e delle passkey, lo sfruttamento delle vulnerabilità risulta in crescita, indicando persistenti criticità nella qualità del codice. Il phishing, invece, mantiene un andamento costante, suggerendo che gli utenti non abbiano sviluppato maggiori capacità di discernimento, che l'uso degli smartphone faciliti errori di interazione a causa di click accidentali e che gli strumenti di AI generativa permettono di generare testi sempre più credibili e privi di errori grammaticali e inconsistenze (che insospettiscono gli utenti).

Asset

Un asset, in ambito di sicurezza informatica, è qualsiasi risorsa di valore per un'organizzazione che deve essere protetta. Può trattarsi di elementi tangibili, come server, dispositivi di rete o database, oppure intangibili, come software, dati, proprietà intellettuale o reputazione.

I grafici relativi alle sezioni sugli asset illustrano quali risorse aziendali siano maggiormente prese di mira e quali tipologie di informazioni vengano più frequentemente sottratte. Tra gli obiettivi principali figurano i server web, i più facilmente raggiungibili, e i server di posta elettronica, utilizzati per acquisire informazioni interne o dati personali.

Tipologie di attacco

Gli attaccanti conducono di solito campagne standard di attacco, non inventano ogni volta tecniche nuove. Per questo motivo, conoscere e categorizzare le tipologie di attacco può aiutare a capire come proteggersi meglio.

I grafici mostrano quali tipologie di attacco risultino più efficaci, evidenziando una significativa variabilità nel tempo. Tra le cause principali si individuano:

- Debolezze tecnologiche e del software (sfruttamento di vulnerabilità)
- Debolezze umane (phishing, errata consegna di informazioni, uso di credenziali compromesse)
- Debolezze organizzative (presenza di backdoor, diffusione di ransomware)

Tempo per rendersi conto

Non tutti gli attacchi sono finalizzati a creare danni immediatamente visibili. Anzi, alcune campagne di attacco puntano a rimanere nascoste subdolamente anche per lunghi periodi. Questo ci fa capire che è anche difficile, in alcuni casi, capire che siamo stati attaccati.

Le analisi riportano spesso la distribuzione del tempo necessario alle organizzazioni per rilevare un attacco subito. Questo fenomeno è parzialmente attribuibile al fatto che gli attaccanti non hanno sempre interesse a rendere pubblica la compromissione: mantenere un accesso persistente all'interno dell'organizzazione può generare maggiori profitti nel tempo. Mediamente, le organizzazioni impiegano diverse settimane per identificare un attacco, con estremi che si estendono a mesi o addirittura anni in alcuni casi.

Un ulteriore tipo di grafico si propone di illustrare i metodi più frequentemente impiegati dalle organizzazioni per identificare un attacco, tra cui spicca il monitoraggio dell'infrastruttura. Un accurato monitoraggio consente di rilevare anomalie comportamentali indicative di compromissioni, facilitando una risposta tempestiva ed efficace.

Tempo di recupero

Le conseguenze degli attacchi informatici possono essere vaste, quindi non è possibile rimediare a tutte le conseguenze in tempi necessariamente brevi.

Per questo motivo, vengono usati dei grafici che riportano i tempi mediani necessari per ripristinare le piene funzionalità operative in seguito a un attacco, nonché i tempi richiesti per rimuovere chiavi pubblicate erroneamente su repository pubblici.

Anche in questo caso, dai dati degli anni passati, si può osservare una significativa variabilità, con tempi di recupero che possono estendersi da giorni a settimane, a seconda della gravità dell'attacco e dell'efficacia delle misure di risposta implementate dall'organizzazione.

1.2 Minacce e problemi di base

L'analisi che segue si propone di illustrare i fattori che hanno condotto all'attuale scenario di vulnerabilità sistemica.

1.2.1 Problemi tecnologici di base

La sicurezza informatica è una problematica relativamente recente. Durante la progettazione delle prime reti, negli anni Settanta, l'obiettivo primario era garantirne il funzionamento operativo (e lo scopo era principalmente militare); la sicurezza non era considerata una priorità, anche in ragione del fatto che tali infrastrutture non erano accessibili al pubblico generale. Inoltre, l'uso di meccanismi crittografici comporta un costo computazionale che i sistemi dell'epoca non erano in grado di sostenere.

Per accedere a Internet, utenti privati e organizzazioni stipulano contratti con Internet Service Provider (ISP), che forniscono l'accesso alla propria infrastruttura di rete. In passato si sono verificati casi in cui dipendenti di ISP hanno sottratto o rivenduto informazioni transitate sulla propria rete, oppure hanno applicato politiche di instradamento anomale per frodare determinati utenti. In generale, dalla prospettiva di un'azienda, un ISP non è necessariamente un ente fidato o può addirittura essere un competitor. Tutto il traffico che attraversa l'infrastruttura di un ISP è tecnicamente accessibile ai suoi operatori, rendendo possibile, ad esempio, la lettura di segreti industriali da parte del personale tecnico di rete.

Un ulteriore problema riguarda l'autenticazione degli utenti, che risulta inadeguata sia per debolezze strutturali dei sistemi sia a causa di comportamenti utente imprudenti, quali l'adozione di password semplici, riutilizzate o già note agli attaccanti.

Infine, come già evidenziato, il software continua a essere sviluppato senza adeguati miglioramenti in termini di sicurezza.

1.2.2 Complessità

Storicamente, la sicurezza informatica era circoscritta alla protezione del sistema operativo. L'architettura tradizionale prevedeva un elaboratore centrale e N postazioni terminali prive di capacità computazionale autonoma (costituite da monitor e tastiera). In tale contesto, proteggere il sistema operativo equivaleva a proteggere l'intera infrastruttura aziendale.

Con l'evoluzione tecnologica, il panorama è mutato radicalmente: si è assistito alla proliferazione di calcolatori sempre più potenti, compatti e accessibili, fino all'avvento degli smartphone. Parallelamente, le infrastrutture di rete hanno subito una trasformazione profonda, con l'emergere di data center, soluzioni cloud, edge computing, fog computing e liquid computing. Tale evoluzione ha reso spesso indeterminabile il luogo fisico di esecuzione delle applicazioni, rendendo complessa l'identificazione del *perimetro di sicurezza* da presidiare.

Nell'attuale scenario, il tentativo di implementare misure di sicurezza si scontra con il seguente principio empirico:

Primo assioma dell'ingegneria. Più un sistema è complesso, più è difficile verificarne la correttezza (implementazione, gestione, funzionamento).

Il paradigma progettuale da adottare è pertanto il **KISS** (*Keep It Simple, Stupid*), che prescrive di mantenere il sistema il più semplice possibile: maggiore è la complessità, maggiore è la probabilità che un attaccante individui vulnerabilità sfruttabili.

Un'analisi interessante sulla correlazione inversa tra crescente potenza computazionale e prestazioni software è disponibile al seguente indirizzo:

`https://tonsky.me/blog/disenchantment/it/`

1.2.3 Altri problemi tecnologici

Ulteriori criticità di natura tecnologica possono derivare da:

- *Problemi di programmazione*: il software contiene bug o non è sviluppato secondo i principi del *secure coding* (ad esempio, validazione insufficiente dei dati di input, gestione inadeguata della memoria, assenza di controlli di accesso);
- *Problemi di progettazione*: la sicurezza non viene considerata come requisito fin dalle fasi iniziali di progettazione, ma viene aggiunta solo in una fase successiva. L'esperienza ha dimostrato che ignorare la sicurezza nelle fasi di concezione del sistema ha storicamente condotto a vulnerabilità gravi e alla necessità di riprogettazioni complete;
- *Configurazione di dispositivi e servizi*: una configurazione inadeguata di server, servizi o sistemi operativi può esporre vulnerabilità verso l'esterno. L'attività di *hardening*[5] richiede competenze tecniche specifiche;
- *Configurazione dei controlli di sicurezza*: molti dispositivi di sicurezza presentano elevata complessità gestionale. In determinati contesti, la configurazione delle politiche di sicurezza aziendali richiede la definizione di un numero considerevole di regole. Alcuni firewall analizzati per identificare errori di configurazione contenevano decine di migliaia di regole [6]. La gestione di tale complessità eccede le capacità cognitive umane, rendendo estremamente difficile prevedere le conseguenze delle interazioni tra le regole.

1.3 Attacchi e tecniche

L'analisi che segue esamina ad alto livello una serie di attacchi fondamentali, comunemente diffusi, presentando, ove disponibili, contromisure note ed efficaci.

Packet sniffing

Il *packet sniffing* è una tecnica di attacco che consiste nell'intercettazione e lettura di pacchetti di rete non destinati all'attaccante. In assenza di cifratura, il contenuto dei pacchetti risulta interamente leggibile, permettendo a chiunque di estrarre informazioni sensibili. Tali informazioni possono essere sfruttate in modo diretto, ad esempio per sottrarre credenziali di accesso e accedere ad account protetti, oppure in modo indiretto, rivelando dettagli interni di un'organizzazione utili per individuare ulteriori vulnerabilità da sfruttare. La contromisura principale consiste nella cifratura del payload dei pacchetti e nella limitazione dell'uso di reti broadcast. Le reti sono state sempre progettate per essere broadcast per ridurre i costi e semplificare la comunicazione; in questo tipo di reti, il packet sniffing risulta particolarmente semplice da realizzare. Reti che prediligono l'uso di switch al posto degli hub riducono l'impatto di questo problema, ma hanno costi decisamente maggiori.

[5] L'hardening è un processo di rafforzamento della sicurezza di un sistema mediante la riduzione della superficie di attacco. Include la disabilitazione di servizi non necessari, l'applicazione di patch, la configurazione restrittiva dei permessi e l'implementazione di controlli di sicurezza aggiuntivi.

[6] Wool, 2010

IP spoofing

Per *IP spoofing* si intende la falsificazione dell'indirizzo di rete di livello 3 (IP). La modifica dell'indirizzo IP è tecnicamente agevole per chi dispone di privilegi amministrativi (basta usare un tool a riga di comando o accedere alle finestre di configurazione della rete), motivo per cui nelle organizzazioni tali privilegi non vengono concessi indiscriminatamente. Questa tecnica consente di falsificare dati o accedere a sistemi in modo non autorizzato. Anche la falsificazione dell'indirizzo di livello 2 (MAC) è semplice, mediante i driver delle schede o manipolando le informazioni di rete delle macchine virtuali. Quindi, sarebbe più corretto parlare di *source address spoofing*. Ne consegue che non è possibile fare affidamento sugli indirizzi di livello 3 o di livello 2 per garantire l'autenticità della comunicazione, rendendo necessario l'impiego di meccanismi di autenticazione non basati su tali informazioni.

Shadow (or fake) server

Nell'attacco di tipo *shadow server*, un elaboratore non autorizzato finge di essere un server legittimo e può anche interporsi nella comunicazione tra un client e un server legittimo. Ciò può avvenire mediante intercettazione della richiesta tramite *packet sniffing*, seguita da *IP spoofing* per impersonare il server legittimo, oppure attraverso la manipolazione delle risposte DNS, in modo da indirizzare il client verso il server falso. In altri casi, sfrutta la mancanza di qualunque forma di autenticazione (es. DHCP) per rispondere al posto del server legittimo senza neanche dover impersonare altre entità. In tal caso, affinché l'attacco abbia successo nel primo caso, il server falso deve rispondere più rapidamente di quello autentico; per questo motivo, talvolta il server legittimo viene deliberatamente rallentato mediante attacchi DDoS. Gli attacchi di questo tipo mirano tipicamente a fornire un servizio fraudolento o apparentemente legittimo alla vittima, oppure a intercettare pacchetti destinati al server autentico. Attualmente, questo tipo di attacco viene contrastato mediante l'impiego di TLS, un protocollo di livello 6 dello stack OSI che stabilisce un'autenticazione unilaterale del server, preservando l'anonimato del client.

Denial of Service (DoS)

Con *Denial of Service* si identificano gli attacchi volti a saturare un host o un server di richieste o messaggi, impedendone la capacità di rispondere in tempi adeguati e compromettendone l'utilizzo per un periodo di tempo più o meno prolungato. Non esiste una soluzione definitiva contro questo tipo di attacchi: il sovradimensionamento dell'infrastruttura costituisce un approccio efficace ma non definitivo, poiché il volume di richieste può sempre eccedere le capacità disponibili. Esistono tuttavia sistemi in grado di rilevare un attacco in corso e, in caso positivo, disconnettere temporaneamente il sistema da Internet, rendendolo irraggiungibile. Al momento, lo strumento più efficace pare essere ancora lo sfruttamento delle relazioni tra persone (es. tra aziende e ISP) che possono collaborare per mitigare gli effetti di questi tipi di attacchi.

Distributed Denial of Service (DDoS)

Con l'aumento della capacità dei sistemi di gestire elevati volumi di traffico, gli attacchi DoS tradizionali, provenienti da un singolo elaboratore, sono diventati meno efficaci (es. un singolo utente non può saturare le risorse di grossi gestori o corporation). Per questo motivo si è sviluppata una variante più sofisticata: il *DDoS*. In questo scenario vengono coinvolti milioni di nodi, denominati *daemon* o *malbot*, che costituiscono una *botnet*. Questi nodi, che possono essere dispositivi comuni compromessi all'insaputa dei proprietari, vengono coordinati per inviare simultaneamente pacchetti verso un unico server bersaglio, moltiplicando l'effetto del DoS per il numero di nodi coinvolti. Un host diventa *daemon* attraverso il download di contenuti non sicuri o la navigazione su siti compromessi, installando processi latenti che vengono attivati successivamente da un computer *master* remoto.

Uno dei primi attacchi di questo tipo ad acquisire rilevanza pubblica portò alla redazione, da parte dell'amministrazione Clinton, di un documento contenente linee guida per prevenire simili eventi. Un caso notevole risale al 2016, quando, oltre ai dispositivi tradizionali, una grande quantità di dispositivi IoT venne infettata dal malware Mirai, riuscendo a compromettere il blog di Krebs, nonostante fosse protetto da Akamai, azienda statunitense specializzata in servizi CDN. Si ritiene che l'attacco fosse collegato alle analisi pubblicate dal blog riguardo ad attacchi simili ai danni di server di gioco online.

Va sottolineato che, secondo importanti studi di avvocati, il coinvolgimento involontario (anche se di solito dovuto a mancanza di misure idonee di sicurezza) di dispositivi nella botnet può consentire alla vittima dell'attacco di intraprendere azioni legali per il recupero dei danni.

Al giorno d'oggi, secondo Cloudflare, che rappresenta la principale fonte di report sul fenomeno DDoS[7], questi attacchi non sono soltanto più frequenti, ma anche più sofisticati e potenti rispetto al passato. Nel 2025 sono stati registrati attacchi con picchi di traffico di 7.3 Tbps, un aumento significativo rispetto ai 3,5 Tbps del 2024, con un flusso di 4.8 miliardi di pacchetti per secondo.

Tra le categorie di attaccanti più attive emergono i **competitor diretti**, che sfruttano il DDoS come strumento di sabotaggio economico per compromettere la disponibilità dei servizi rivali. L'obiettivo è causare perdite economiche dirette, erodere la fiducia dei clienti e danneggiare la reputazione dell'avversario. In settori altamente competitivi quali e-commerce, streaming e gaming online, anche brevi interruzioni del servizio possono spingere la clientela a migrare verso competitor che paiono garantire maggiore affidabilità. Tali attacchi sono frequentemente orchestrati in concomitanza con eventi critici come lanci di prodotti, picchi di vendite o campagne promozionali, al fine di massimizzarne l'impatto economico. La crescente disponibilità di servizi DDoS-as-a-Service sul dark web ha inoltre reso questa forma di sabotaggio accessibile anche ad attori privi di competenze tecniche avanzate.

Man In The Middle (o connection hijacking)

Negli attacchi di tipo *Man In The Middle* (**MITM**) l'attaccante si interpone nella comunicazione tra due host, acquisendo la capacità di leggere il traffico, manipolarlo, eliminare messaggi o aggiungerne di nuovi in tempo reale, compatibilmente con i tempi fisici di trasmissione. Una sottocategoria di questi attacchi è anche nota come *data spoofing*. Per contrastare questo tipo di attacchi è necessario garantire: riservatezza (solo il destinatario legittimo può leggere il messaggio), autenticazione (certezza che nessuno si stia fingendo il destinatario), integrità (il messaggio non deve essere modificato prima di raggiungere il destinatario) e serializzazione (assegnazione di un identificativo univoco a ogni pacchetto).

1.3.1 Malware

Il termine *malware* identifica l'insieme dei software progettati per arrecare danno ai sistemi informatici. Tra questi si distinguono:

- **Virus**: software malevolo caratterizzato da elevata aggressività, il cui obiettivo è danneggiare il sistema e replicarsi. La propagazione avviene spesso con la collaborazione involontaria degli utenti (es. aprire file sospetti, disabilitare i controlli dei sistemi operativi, scaricare crack).
- **Worm**: software malevolo il cui scopo principale è la replicazione e la propagazione verso il maggior numero possibile di sistemi, senza necessità di intervento umano. Sfrutta vulnerabilità di rete per diffondersi, saturando le risorse disponibili. Il fatto che si replichi senza controllo saturando le risorse rappresenta il danno arrecato.
- **Backdoor**: punto di accesso non autorizzato a un sistema. Può essere inserita intenzionalmente dal produttore dell'hardware per consentire aggiornamenti di firmware senza notificare

[7] The Cloudflare Blog, 2025

l'utente, oppure può essere creata da un trojan per permettere all'attaccante di accedere facilmente al sistema in qualsiasi momento.

- **Trojan**: programma apparentemente innocuo che nasconde al suo interno codice malevolo e che ha il ruolo di aprire una breccia nei sistemi da compromettere[8]. È progettato per colpire principalmente host individuali piuttosto che server, generalmente più protetti e dove si può contare mediamente meno sull'impreparazione del personale. Può rimanere latente per periodi prolungati mentre gli attaccanti individuano un punto di accesso al sistema. Una volta attivato può svolgere azioni dannose, aprire backdoor, esfiltrare dati, iniettare altri programmi che servono ad acquisire privilegi di amministrazione o bot per DDoS.
- **Rootkit**: insieme di strumenti nascosti per l'accesso privilegiato, installati nel sistema per consentirne l'amministrazione remota non autorizzata.

In generale, i malware continuano a dimostrarsi efficaci poiché sfruttano l'anello debole della catena di sicurezza: il fattore umano. Gli utenti contribuiscono involontariamente alla propagazione del malware. Per contrastare questa minaccia è necessario prestare particolare attenzione alla configurazione dei software e mantenere costantemente aggiornati i sistemi, senza rimandare indefinitamente tali operazioni.

1.3.2 Ransomware

Il *ransomware* è una categoria particolare di malware il cui obiettivo consiste nel cifrare i dati del sistema bersaglio, in tutto o in parte, al fine di richiedere un riscatto per la sua decifratura. In alcuni casi, gli attaccanti si fingono rappresentanti delle forze dell'ordine per aumentare la pressione psicologica sulla vittima. Come evidenziato dai dati, l'utilizzo di questo tipo di attacco mostra una tendenza crescente nel tempo, poiché molte vittime preferiscono pagare il riscatto senza denunciare l'accaduto per evitare ripercussioni reputazionali, sebbene il pagamento non garantisca il recupero dei dati. Sono comunque dei criminali e anche se non decifrare i dati crea loro danno reputazionale, non si esporranno né si preoccuperanno troppo nel caso non riuscissero a decifrare i dati.

Ransomware vs. organizzazione

Nelle organizzazioni, specialmente in quelle di grandi dimensioni, è prassi consolidata effettuare backup periodici dei dati, data l'impossibilità di tollerare la perdita di informazioni critiche. Tuttavia, nel caso ci servisse ripristinare i dati in seguito ad un attacco ransomware, possono emergere un insieme di criticità rilevanti. Prima di tutto, è importante capire quanto tempo prima dell'attacco è stato effettuato l'ultimo backup. Il backup potrebbe infatti contenere il ransomware in stato latente, non ancora attivato (*ransomware silente*). Ciò genera un circolo vizioso: il sistema viene compromesso, si ripristina il backup, ma il ransomware presente in esso si riattiva dopo un certo periodo, causando una nuova compromissione. L'utilizzo del cloud per il backup non cambia la situazione. Il ransomware può infiltrarsi e cifrare tutti i dischi di rete e le risorse cloud raggiungibili dalla macchina infetta. Quello che è importante è avere anche un backup offline su cui riversare periodicamente (es. una volta al giorno) i backup online (server sempre raggiungibili). In questo modo si riduce drasticamente la finestra di esposizione al rischio che il ransomware cifri anche quei dati.

Un caso emblematico di un problema di gestione dei backup riguarda un'organizzazione svedese che effettuava backup su nastro magnetico (molto più economico dei dischi per grandi quantità di dati), trasportato manualmente in un archivio situato in un edificio separato. Durante il trasporto, il nastro veniva appoggiato sui sedili riscaldati dell'auto, causando il danneggiamento del supporto. Il problema non fu rilevato tempestivamente poiché nessuno aveva mai verificato l'effettiva funzionalità dei backup. È quindi indispensabile verificare periodicamente le procedure di ripristino e la qualità dei dati salvati.

[8] Per approfondire: Fortinet, 2025

Un altro caso significativo coinvolse un archivio televisivo, in cui l'infezione da ransomware non era stata scoperta per un periodo talmente prolungato da compromettere decenni di contenuti audiovisivi. Questi episodi dimostrano che un backup eseguito senza criteri rigorosi non costituisce una protezione efficace contro i ransomware. Solo backup periodici, costantemente verificati e testati, possono garantire un recupero tempestivo in caso di compromissione.

1.3.3 Industria del Cybercrime

La diffusione degli attacchi informatici ha favorito lo sviluppo di una vera e propria industria del crimine informatico, strutturata come una *supply chain* in cui vengono commercializzati prodotti e servizi quali: malware progettati per attacchi specifici, servizi DDoS, credenziali sottratte, vulnerabilità e relativi exploit, call center impiegati per fornire i codici OTP in sistemi di autenticazione a due fattori comuni (più frequenti in USA) e *money mule*. Quest'ultima categoria si riferisce a individui che partecipano a operazioni di riciclaggio: quando vengono sottratti fondi da conti bancari, questi vengono trasferiti su conti intermediari gestiti dai *money mule*, i quali prelevano il contante tramite bancomat per renderlo non tracciabile. Per questo motivo, gli attori criminali tendono a raccogliere grandi quantità di dati, incluse le credenziali di accesso, per rivenderli sul *dark web*. I prezzi di tali servizi sono mantenuti relativamente contenuti per renderli accessibili a un'ampia gamma di acquirenti, privilegiando la numerosità delle transazioni rispetto al valore unitario elevato.

Come se non bastasse, questo fenomeno del Crime-as-a-Service (CaaS) ha reso il crimine informatico accessibile anche a individui privi di competenze tecniche avanzate, ampliando significativamente la base di potenziali attaccanti e contribuendo alla crescita esponenziale degli incidenti di sicurezza informatica a livello globale.

1.4 Altri problemi e minacce

Nel contesto della cybersecurity, l'essere umano rappresenta notoriamente l'elemento più vulnerabile della catena difensiva. Nonostante l'evoluzione delle tecnologie di protezione, quali firewall, crittografia e sistemi di rilevamento delle intrusioni, l'efficacia complessiva di un sistema informatico dipende in larga misura dal comportamento degli utenti, degli amministratori e degli operatori coinvolti.

Le principali aree in cui gli errori umani producono il maggior impatto sono:

- **Abuso di credenziali**: la scelta di password banali, l'utilizzo improprio, la condivisione o la gestione non sicura di credenziali (password, token, accessi) rappresentano una delle principali cause di compromissione dei sistemi. Attacchi quali il *credential stuffing* sfruttano credenziali sottratte o riutilizzate per accedere a servizi sensibili.
- **Azioni sociali**: tecniche di manipolazione psicologica, come il phishing o lo spear phishing, inducono gli utenti a rivelare informazioni riservate o a compiere azioni dannose, spesso sfruttando la fiducia o la pressione emotiva.
- **Errori**: configurazioni errate, mancati aggiornamenti, gestione superficiale delle risorse o semplici disattenzioni possono aprire vulnerabilità sfruttabili dagli attaccanti.
- **Malware**: l'esecuzione involontaria di software malevolo, spesso tramite allegati o link ricevuti via email o messaggi, può compromettere dati, sistemi e reti, propagandosi rapidamente a causa di comportamenti poco attenti degli utenti.

1.4.1 Alcuni esempi di attacchi riconducibili a errori umani

I successivi paragrafi riportano alcuni esempi di attacchi famosi. Analizzarli è utile per capire quali debolezze sono state sfruttate e come provare a rimediare.

Caso di studio 1: Wind Infostrada, ottobre 2017

Un caso emblematico della vulnerabilità dei sistemi digitali causata da errori umani è l'incidente Wind Infostrada del 2017[9]. Nei primi giorni di ottobre, migliaia di utenti della rete in fibra subirono un'interruzione totale della connettività: i modem forniti dall'operatore risultarono *bricked*, ovvero completamente inutilizzabili, resi inaccessibili da remoto e irrimediabilmente compromessi.

La causa fu una grave falla di sicurezza: i dispositivi avevano la porta Telnet (8023) aperta e accessibile da Internet, con credenziali di default impostate su `admin/admin`. Questa configurazione, pensata per permettere l'aggiornamento trasparente dei dispositivi, permise al malware BrickerBot di accedere ai modem e sovrascriverne il firmware con codice casuale. L'attacco, seppur distruttivo, ebbe l'effetto collaterale di impedire che i dispositivi venissero arruolati in botnet o sfruttati per attività malevole come furto di dati o mining illecito.

Un anno prima, un episodio simile ma su scala più ampia aveva coinvolto Deutsche Telekom, dove una vulnerabilità nei router aveva causato disservizi a centinaia di migliaia di utenti. Anche in quel caso, decisioni incaute, configurazioni errate, protocolli obsoleti e mancanza di valutazione dell'impatto di sicurezza di determinate scelte avevano aperto la porta a tentativi di compromissione su vasta scala.

Attualmente, per contrastare i rischi legati alla sicurezza informatica e alla gestione dei dati, molte organizzazioni hanno adottato sistemi di autenticazione significativamente più robusti. Tra le misure più efficaci si annovera l'**utilizzo di password uniche e complesse**, generate automaticamente e mai lasciate ai valori di default, al fine di evitare accessi non autorizzati dovuti all'uso di credenziali banali. A queste si affianca l'autenticazione a più fattori (**MFA**, Multi-Factor Authentication), che aggiunge un ulteriore livello di protezione per l'accesso alle aree riservate e ai sistemi critici. Un altro passo fondamentale è la **disabilitazione dei protocolli legacy** come Telnet, ormai considerati insicuri, e la loro sostituzione con soluzioni più moderne e cifrate come SSH o VPN. Infine, le organizzazioni più mature dal punto di vista della sicurezza implementano **audit periodici e sistemi di monitoraggio attivo**, capaci di rilevare tempestivamente anomalie e modifiche non autorizzate. Queste pratiche, se integrate in una governance chiara e accompagnate da una responsabilizzazione contrattuale dei fornitori, costituiscono oggi il fondamento di una resilienza operativa consapevole, capace di rispondere con efficacia alle minacce emergenti.

Caso di studio 2: i mercatini di Peshàwar, 2009

Nel 2009, nei mercatini di Peshàwar, città pakistana situata al confine con l'Afghanistan, furono rinvenuti diversi computer portatili appartenenti ai Marine statunitensi, messi in vendita da commercianti locali[10]. Questi dispositivi, presumibilmente smarriti o sottratti durante operazioni sul campo, contenevano documenti riservati, mappe operative e comunicazioni interne, spesso non protetti da alcuna forma di crittografia. La facilità con cui tali informazioni finirono in circuiti commerciali informali evidenziò quanto sia vulnerabile l'infrastruttura digitale quando non supportata da misure di sicurezza robuste e da una formazione adeguata del personale.

L'episodio andò oltre il danno economico di rimpiazzare l'hardware perso, poiché espose dati sensibili che avrebbero potuto essere sfruttati da gruppi ostili per pianificare attacchi o sabotaggi. La mancanza di protocolli di sicurezza adeguati, quali l'uso di crittografia forte per i dati a riposo (es. cifratura dei dischi) e l'implementazione di sistemi di tracciamento e cancellazione remota, evidenziò una lacuna significativa nella gestione della sicurezza informatica in contesti operativi ad alto rischio.

[9] securityinfo.it, 2017

[10] Corriere della Sera, 2009

1.4.2 Ingegneria sociale

Una delle vulnerabilità più insidiose nella sicurezza informatica è la predisposizione umana alla fiducia, specialmente in contesti professionali o sociali. Gli attaccanti sfruttano questa tendenza attraverso tecniche di **ingegneria sociale**, mirate a manipolare le vittime affinché compiano azioni che compromettono la sicurezza o rivelino informazioni riservate.

Phishing

Il *phishing* è una tecnica fraudolenta che consiste nell'invio di comunicazioni ingannevoli (tipicamente email, ma anche SMS o messaggi su piattaforme digitali) che simulano provenienza da enti affidabili, quali istituti bancari, organizzazioni o colleghi. L'obiettivo è indurre l'utente a fornire informazioni sensibili, come credenziali di accesso, dati personali o finanziari, o a compiere azioni che compromettono la sicurezza del sistema.

Esistono due varianti principali del phishing:

Spear phishing: attacco mirato a un individuo specifico (o un piccolo gruppo omogeneo), con contenuti personalizzati basati su informazioni raccolte in precedenza (ad esempio, ruolo aziendale, progetti in corso). L'elevato grado di verosimiglianza aumenta la probabilità di successo.

Whaling: forma di spear phishing rivolta a figure apicali (ad esempio, CEO, CFO), con comunicazioni che simulano richieste urgenti o transazioni strategiche. Data la posizione della vittima, il potenziale impatto è particolarmente elevato.

Pretexting

Il *pretexting* si basa sulla costruzione di un **pretesto credibile** per ottenere informazioni sensibili. L'attaccante si presenta con un'identità falsa e una narrazione coerente, spesso supportata da dettagli plausibili, per giustificare la richiesta. A differenza del phishing, il pretexting può avvenire anche tramite telefono o di persona.

Esempi comuni includono:

- Fingersi un tecnico IT che necessita di verificare le credenziali;
- Impersonare un collega del reparto risorse umane per aggiornare dati personali;
- Simulare una chiamata da parte della banca per confermare movimenti sospetti.

Tutte queste tecniche si basano sull'abilità dell'attaccante nel stabilire un rapporto di fiducia e sfruttare contesti familiari o l'urgenza. La consapevolezza e la formazione degli utenti sono strumenti fondamentali per contrastare questi attacchi.

Caso di studio 3: il caso Confindustria, 2017

Nel 2017, Confindustria fu vittima di una truffa informatica che portò alla perdita di circa 500.000 euro[11].

L'episodio, rimasto in parte avvolto nel mistero, rappresenta un caso emblematico di *Business Email Compromise*, una tecnica di attacco basata sull'ingegneria sociale e sull'inganno psicologico. I truffatori si finsero fornitori abituali dell'associazione, utilizzando un indirizzo email contraffatto ma verosimile. Il messaggio, redatto in modo professionale e contestuale (sapevano che il manager era impegnato in una riunione; hanno simulato lo stile di scrittura), richiedeva il pagamento urgente di una fattura su un nuovo conto bancario estero (in paradisi fiscali). La comunicazione faceva leva su elementi chiave dell'ingegneria sociale: l'urgenza dell'operazione, l'apparente autorevolezza del mittente e la familiarità con le procedure interne. Il bonifico fu eseguito senza ulteriori verifiche.

Questo evento dimostra quanto siano cruciali la formazione del personale, l'adozione di protocolli di verifica e la consapevolezza dei rischi legati alla manipolazione psicologica. L'ingegneria sociale non si basa sulla forza bruta, ma sulla capacità di sfruttare le debolezze umane e organizzative.

[11] Il Fatto Quotidiano, 2017

Caso di studio 4: phishing via Transformer 3, 2010

Nel 2010, la base aerea statunitense di Andersen (Guam) condusse un'esercitazione di sicurezza informatica per sensibilizzare il personale militare sui rischi del phishing[12]. L'esercizio consistette nell'invio di email false che annunciavano la presunta produzione del film Transformers 3 sull'isola, invitando i destinatari a candidarsi come comparse o membri dello staff. Il sito collegato alle email richiedeva informazioni personali e militari, simulando un attacco di phishing realistico.

L'obiettivo era duplice: testare la reattività del personale e generare consapevolezza sui rischi delle comunicazioni fraudolente. Tuttavia, l'esercizio ebbe effetti collaterali imprevisti. Molti destinatari condivisero l'informazione sui forum online, contribuendo alla diffusione virale della notizia. Il risultato fu un'ondata di speculazioni mediatiche locali sull'arrivo della produzione cinematografica, il che rese necessario il rilascio di una dichiarazione ufficiale per chiarire l'equivoco.

1.4.3 Attacchi famosi

Stuxnet

Nel 2009, l'attacco informatico alla centrale nucleare iraniana di Natanz segnò un punto di svolta nella storia della sicurezza informatica globale. Il malware Stuxnet[13], sviluppato congiuntamente dagli Stati Uniti e da Israele (secondo fonti non ufficiali), rappresenta il primo esempio documentato di arma cibernetica progettata per causare danni fisici a infrastrutture critiche. Non si trattava più di furto di dati o spionaggio digitale, ma di sabotaggio industriale su scala nazionale.

L'obiettivo era rallentare il programma nucleare iraniano senza ricorrere a un attacco militare convenzionale: una volta introdotto nei sistemi della centrale tramite una chiavetta USB, il worm si attivava solo in presenza di una configurazione specifica di controllori logici programmabili (PLC) Siemens, utilizzati per regolare la velocità delle centrifughe per l'arricchimento dell'uranio. Il malware alterava la velocità dei rotori senza che questa venisse riportata dagli strumenti di monitoraggio dell'infrastruttura, causando danni meccanici progressivi, mentre forniva feedback falsi agli operatori, rendendo difficile individuare l'origine del malfunzionamento.

La sofisticazione dell'attacco è testimoniata dall'impiego di almeno cinque vulnerabilità zero-day, un numero senza precedenti per un singolo malware. Inoltre, circa la metà del codice era dedicata esclusivamente ad evitare il rilevamento.

Brutal Kangaroo

Brutal Kangaroo[14], rivelato nel 2017 attraverso i leak di WikiLeaks, rappresenta una delle più sofisticate strategie di infiltrazione sviluppate dalla CIA per compromettere sistemi **air-gapped**, ovvero computer isolati fisicamente da qualsiasi rete. L'obiettivo era superare il paradigma della sicurezza per isolamento, dimostrando che anche i dispositivi scollegati da Internet possono essere bersagliati con successo. A differenza di Stuxnet, che mirava a sabotare infrastrutture critiche, Brutal Kangaroo era progettato per l'esfiltrazione di dati sensibili da reti altamente protette, con un controllo invisibile e duraturo.

Il framework si compone di una serie di strumenti modulari che operano in sinergia. Il punto di ingresso è solitamente un computer connesso alla rete, infettato tramite un payload nascosto in documenti o file eseguibili. Una volta compromesso, questo sistema agisce come *Primary Host* e prepara chiavette USB contenenti un malware secondario, chiamato *Drifting Deadline*, progettato per attivarsi quando la chiavetta viene inserita in un sistema air-gapped.

Il malware è in grado di raccogliere informazioni, esfiltrare dati e persino propagarsi ulteriormente, sfruttando vulnerabilità locali e tecniche di steganografia per nascondere i dati all'interno di

[12] The Register, 2010
[13] ICT Security Magazine, 2021
[14] securityinfo.it, 2017

file apparentemente innocui. L'intero processo è pensato per operare in modo silenzioso, con un alto grado di persistenza e capacità di evasione.

Black Energy

BlackEnergy[15] è un malware modulare adattato per colpire infrastrutture critiche. Originariamente sviluppato per attacchi DDoS e campagne di spam, ha subito una profonda evoluzione fino a diventare uno strumento di sabotaggio industriale.

La sua notorietà è legata in particolare all'attacco del dicembre 2015 contro la rete elettrica ucraina, in cui BlackEnergy fu utilizzato per compromettere sistemi SCADA e causare blackout in diverse regioni per diverse ore. L'operazione, attribuita a gruppi APT legati alla Russia, ha dimostrato come un malware possa essere integrato in una campagna multi-vettoriale.

BlackEnergy si distingue per la sua architettura modulare: il payload principale può essere esteso con plugin specifici per la raccolta di credenziali, l'esfiltrazione di dati, il controllo remoto e la distruzione di file. La sua capacità di persistenza e la compatibilità con ambienti industriali lo rendono particolarmente pericoloso in contesti SCADA e ICS.

L'attacco alla rete ucraina ha evidenziato anche l'uso di tecniche di spear phishing per la diffusione iniziale, con allegati malevoli mascherati da documenti legittimi. Una volta installato, il malware agiva in modo silente, raccogliendo informazioni e preparando l'ambiente per l'interruzione dei servizi.

Proprio per la sua natura, Black Energy è un esempio di **Advanced Persistent Threat (APT)**, una minaccia (Threat) sviluppata con tecniche avanzate (Advanced) che resta nascosta ed operativa per periodi molto lunghi (Persistent).

Mirai

Il malware Mirai[16] ha segnato una svolta epocale nella storia delle botnet, dimostrando il potenziale distruttivo dell'Internet of Things (IoT) quando sfruttato come vettore di attacco. Scoperto nel 2016, Mirai è progettato per infettare dispositivi IoT basati su processori ARC che eseguono versioni ridotte di Linux. Una volta compromessi, questi dispositivi diventano *zombie* all'interno di una botnet controllata da remoto, utilizzata principalmente per attacchi DDoS su larga scala.

Il meccanismo di infezione è semplice: Mirai effettua una scansione automatica della rete alla ricerca di dispositivi con credenziali di default non modificate. Una volta individuato un target vulnerabile, il malware si installa e stabilisce una connessione con un server di comando e controllo (C&C), pronto a ricevere istruzioni per lanciare attacchi coordinati. La categoria di IoT infetta era costituita da sistemi relativamente complessi ed in grado di trasmettere una grande quantità di dati (es. diversi tipi di baby monitor), quindi molto interessante per attacchi DDoS.

Il primo attacco noto fu diretto contro il sito di un esperto di sicurezza (Krebs on Security), ma il vero impatto si manifestò nell'ottobre 2016, quando un attacco DDoS contro il provider DNS Dyn causò l'interruzione di servizi come Twitter, Netflix e Reddit. L'attacco coinvolse oltre 100.000 dispositivi IoT compromessi.

Dopo l'arresto degli autori originali, il codice sorgente di Mirai fu pubblicato online e reso open source, dando origine a numerose varianti. Inoltre, la semplicità d'uso dei kit Mirai ha favorito la proliferazione del malware anche tra attori con competenze tecniche limitate.

Attacchi noti con Mirai includono:

- Krebs on Security (2016) - fino a 620 Gbps
- Ars Technica (2016) - fino a 100 Gbps
- OVH (2016) - fino a 1 Tbps
- Dyn (2016) - fino a 1.2 Tbps

[15] cybersecurity360.it, 2021
[16] Cloudflare, 2025

BlueBorne

BlueBorne[17] è una minaccia informatica emersa nel 2017 che ha evidenziato il protocollo Bluetooth come una nuova superficie d'attacco. BlueBorne non richiede che il dispositivo target sia connesso a Internet o che accetti connessioni Bluetooth in ingresso; è sufficiente che il Bluetooth sia attivo per comprometterlo in meno di dieci secondi.

Il malware è classificato come Trojan-Worm ibrido: una volta infettato, il dispositivo diventa a sua volta vettore di propagazione, cercando attivamente altri host vulnerabili nelle vicinanze. BlueBorne colpisce una vasta gamma di sistemi operativi, tra cui Android, iOS, Windows e Linux, rendendo vulnerabile qualsiasi dispositivo con Bluetooth abilitato.

Sfrutta diverse vulnerabilità, tra cui buffer overflow e problemi di gestione della memoria, per eseguire codice arbitrario con privilegi elevati. Una volta installato, può effettuare MITM, esfiltrare dati, installare ulteriori malware e persino consentire il controllo completo da remoto del dispositivo. Avendo colpito diversi tipi di sistemi di infotainement di veicoli l'impatto anche sulla sicurezza fisica (*safety*) è evidente.

1.5 Sicurezza: definizioni

La sicurezza informatica è l'insieme dei processi, delle tecnologie e delle politiche che mirano a proteggere le informazioni e i sistemi informatici da accessi non autorizzati, alterazioni, distruzioni o interruzioni dei servizi. L'obiettivo è ridurre i rischi entro limiti accettabili, garantendo la disponibilità, l'integrità e la riservatezza delle risorse informative.

Di seguito sono riportate le principali proprietà che caratterizzano la sicurezza dei sistemi informatici.

1.5.1 Riservatezza

La riservatezza è la proprietà che assicura che le informazioni siano accessibili esclusivamente a soggetti, entità o processi autorizzati, prevenendo così la divulgazione o l'esposizione dei dati a terze parti non autorizzate. Questo principio si applica tanto alle informazioni digitali (come file e dati trasmessi in rete) quanto a quelle fisiche e personali, incluse preferenze, dati relativi alla posizione geografica e dati sensibili, come l'origine etnica, le opinioni politiche, le convinzioni religiose o filosofiche, l'orientamento sessuale, dati biometrici, genetici e sanitari.

La riservatezza viene garantita attraverso un insieme coordinato di misure tecniche e organizzative, come crittografia end-to-end, protocolli sicuri, controlli degli accessi, sistemi di autenticazione e gestione delle credenziali.

La riservatezza è una proprietà distinta dalla privacy. Sebbene i metodi per garantirle siano spesso comuni, la privacy si focalizza più sulla protezione dei dati personali e sull'autonomia di ogni singolo individuo nell'uso e nella concessione di questi dati. La privacy è regolata da normative sulla protezione dei dati, come il GDPR, che definiscono modi accettabili di uso dei dati personali e sensibili degli utenti, limitano la profilazione e disciplinano la raccolta e il trattamento delle informazioni personali.

1.5.2 Integrità

L'integrità assicura che le informazioni e i sistemi rimangano corretti, completi e coerenti nel tempo. In una comunicazione, ciò significa che il destinatario deve ricevere esattamente i dati inviati dal mittente, senza modifiche, omissioni (*cancellazione/filtraggio*) o duplicazioni non autorizzate (*attacchi di tipo replay*). L'integrità si tutela attraverso tecniche che prevedono il calcolo di codici di controllo (resistenti agli attacchi), es., con funzioni di hash, firme digitali e sistemi di versionamento.

[17] ICT Security Magazine, 2017

Questi codici vengono calcolati sui dati al momento in cui il loro stato di integrità è certo (es. prima della trasmissione). Ricalcolando gli stessi a posteriori, quando i dati potrebbero aver subito modifiche, si riesce a capire se le modifiche ci sono state o meno.

Invece, omissioni e duplicazioni possono essere identificate numerando tutti i dati.

1.5.3 Autenticazione della controparte

L'autenticazione è il processo mediante il quale un'entità verifica l'identità di un'altra. Essa permette di accertare che chi o ciò con cui si sta comunicando sia effettivamente chi dichiara di essere. L'autenticazione può essere:

- *singola*, quando solo una delle due entità verifica l'identità dell'altra;
- *mutua*, quando entrambe le entità si autenticano reciprocamente.

L'autenticazione può basarsi su uno o più fattori: qualcosa che l'utente conosce (ad esempio, password), possiede (ad esempio, token o smart card) o rappresenta (ad esempio, dati biometrici). I principi dell'autenticazione e i meccanismi per ottenerli saranno trattati più nel dettaglio nel capitolo **??**.

1.5.4 Autenticazione dei dati

L'autenticazione dei dati è la proprietà che consente di verificare l'origine e l'autenticità delle informazioni, garantendo che esse provengano effettivamente dal soggetto dichiarato. È strettamente legata all'integrità, poiché non avrebbe senso verificare l'origine dei dati se essi potessero essere modificati da terzi. Gli strumenti comunemente impiegati per l'autenticazione dei dati includono codici MAC (*Message Authentication Code*) e firme digitali.

L'autenticazione dei dati è necessaria tutte le volte in cui i dati vengono trasmessi. Infatti, dopo aver autenticato la controparte, è necessario controllare che i dati della comunicazione provengano ancora dalla stessa entità precedentemente autenticata (per come sono fatte le reti, un MITM potrebbe interferire con le comunicazioni). Inoltre, è necessaria quando si devono preservare dei documenti (es. atti o contratti).

1.5.5 Non ripudio

Il non ripudio è la proprietà che impedisce a un soggetto o a un'entità di negare in seguito di aver compiuto un'azione o generato determinate informazioni. Questa caratteristica garantisce un valore probatorio, spesso riconosciuto anche a livello legale, nelle comunicazioni digitali, nelle transazioni elettroniche e nei contratti informatici.

I meccanismi tecnici che lo supportano comprendono tipicamente firme digitali, protocolli crittografici e sistemi di tracciamento sicuro. Ma il non ripudio non è solo una questione tecnologica: riveste un ruolo centrale anche in ambito giuridico, dove leggi, regolamenti e la consulenza di avvocati definiscono come i dati e le prove digitali possano essere raccolti, conservati e validati affinché abbiano efficacia legale.

Ad esempio, oltre agli aspetti legali, per avere il non ripudio è richiesta anche la dimostrazione che da parte degli utenti ci fosse comprensione chiara delle operazioni che stavano svolgendo: un'azione digitale deve essere consapevole per poter attribuire responsabilità. È anche necessario che le interfacce informatiche siano ben fatte, prive di errori involontari o dolosi (es., cambiare il testo dei pulsanti di un'interfaccia grafica da Sì a No per ingannare gli utenti). In assenza di ciò, possono insorgere rischi come estorsioni digitali, phishing o l'uso di interfacce fraudolente che simulano operazioni legittime per ottenere firme o autorizzazioni ingannevoli.

In pratica, garantire il non ripudio richiede un approccio integrato che unisca strumenti tecnici e considerazioni normative, procedure contrattuali e responsabilità legali.

1.5.6 Autorizzazione (o controllo degli accessi)

L'autorizzazione è il processo che stabilisce quali operazioni un utente o un processo può eseguire su una risorsa. Si concretizza attraverso politiche di controllo degli accessi, che determinano i diritti di lettura, scrittura o esecuzione in base a ruoli, livelli di sicurezza o altre regole dell'organizzazione. La gestione del controllo di accessi può essere modellata con enormi matrici (multidimensionali) che uniscono, tra le altre cose, utenti, ruoli, risorse, privilegi e azioni permesse. Tuttavia, per migliorarne l'usabilità e ottimizzare lo sfruttamento (es. con dei workflow dedicati), sono stati proposti in letteratura diversi modelli. Tra i principali modelli di controllo degli accessi si distinguono:

- *Role-Based Access Control (RBAC)*: i permessi vengono assegnati in base ai ruoli degli utenti (es. amministratore, utente, sviluppatore), che vengono solo successivamente assegnati agli utenti, facilitando la gestione centralizzata dei privilegi;
- *Identity-Based Access Control (IBAC)*: i privilegi sono assegnati direttamente a utenti specifici, senza mediazione di ruoli o attributi; questo modello è semplice ma poco scalabile;
- *Attribute-Based Access Control (ABAC)*: le decisioni di accesso vengono prese in base a funzioni che verificano un insieme di attributi assegnati a utenti e risorse, rispetto ad azioni richieste e contesto (es. reparto, classificazione dei dati, luogo, orario di accesso);
- *Relationship-Based Access Control (ReBAC)*: i permessi derivano dalle relazioni tra entità; questi modelli sono tipicamente usati nei social network e in sistemi collaborativi (es. un utente può vedere i dati solo dei suoi "amici" o "colleghi");
- *Mandatory Access Control (MAC)*: l'accesso è regolato da una politica di sicurezza centralizzata implementata direttamente dai sistemi (hardcoded e quindi non configurabile o disattivabile) basata su classificazioni e livelli di sensibilità delle informazioni (es. sistemi militari in cui i documenti classificati come "riservati", "segreti", "top secret" sono accessibili solo da processi che abbiano etichette compatibili);

1.5.7 Protezione dei dati

La protezione dei dati comprende l'insieme delle misure tecniche e organizzative volte a preservare riservatezza, integrità e autenticità delle informazioni, sia durante la trasmissione (*dati in movimento*) sia durante la memorizzazione (*dati a riposo*). Essa può anche includere pratiche di cifratura, gestione sicura delle credenziali, backup periodici e controlli di accesso. A livello normativo, la protezione dei dati è strettamente connessa al rispetto della privacy e della conformità legislativa (ad esempio, GDPR).

1.6 Principi di sicurezza

I principi di sicurezza sono un metodo per riassumere in maniera chiara ed efficace metodologie e approcci corretti o specifici rispetto alla sicurezza informatica.

In diversi standard, è possibile trovare questi tre principi progettuali fondamentali:

- *Security by design*: indica il desiderio o la necessità di integrare la sicurezza sin dalle prime fasi di progettazione di un sistema. In contesti di questo tipo le soluzioni necessarie a garantire proprietà di sicurezza diventano parte integrante dell'architettura, dei processi e del ciclo di sviluppo. L'obiettivo è anticipare o prevenire vulnerabilità e minacce in modo proattivo, garantendo che i requisiti di sicurezza siano trattati come componenti essenziali del sistema e non come interventi correttivi successivi (approccio che negli anni si è rivelato fonte di diversi problemi e attacchi), rafforzando così la responsabilità di produttori e sviluppatori;
- *Security by default*: indica un approccio all'implementazione delle misure di sicurezza di un sistema che prevede che il sistema sia sicuro (o al livello di sicurezza più alto possibile) nella sua configurazione iniziale. Ciò implica che impostazioni, permessi e servizi predefiniti siano configurati con criteri restrittivi, trasferendo il compito di configurare correttamente la

sicurezza sul produttore e consentendo anche agli utenti meno esperti di operare in modo protetto, senza richiedere modifiche o interventi complessi da parte dell'utente finale. Questo principio prova a mitigare i rischi dovuti ai precedenti approcci, in cui i sistemi venivano preparati per essere più performanti e minimizzare i 'fastidi' dati dalle restrizioni di sicurezza all'usabilità. Per eliminare delle misure di sicurezza è necessario un intervento esplicito, che determina anche una responsabilità esplicita, es. dell'utente, nel caso il sistema fosse compromesso a causa di una vulnerabilità sfruttabile in seguito a tale eliminazione.

- *Defense in depth*: indica un approccio in cui si prova a rafforzare la sicurezza stratificando le protezioni su più livelli, combinando soluzioni tecniche, procedurali e organizzative e facendo uso di ridondanza. Questo approccio presuppone, correttamente, che nessuna singola misura sia sufficiente a garantire la protezione completa: se un livello viene violato, gli altri dovrebbero continuare a funzionare come barriere aggiuntive, riducendo la probabilità di una compromissione ed i conseguenti impatti.

Insieme, questi principi definiscono un approccio sistematico e robusto alla progettazione della sicurezza, che mira a prevenire, mitigare e gestire le minacce in modo efficace.

Il NIST[18] aggiunge altri due principi fondamentali:

- *Need-to-know*: un utente di un sistema informatico deve accedere esclusivamente alle informazioni strettamente necessarie per svolgere le proprie attività. Questo principio limita il numero di utenti che possono accedere a informazioni e di conseguenza l'esposizione ai dati confidenziali o sensibili; riduce quindi la probabilità che informazioni riservate vengano divulgate involontariamente o abusivamente;
- *Least privilege*: un processo o un utente deve disporre solo dei privilegi minimi indispensabili per portare a termine le operazioni perviste dal suo ruolo e dalle sue mansioni. Questo principio è pensato per evitare concessioni eccessive come diritti amministrativi non necessari, privilegi di sistema elevati o accessi permanenti a risorse critiche. L'implementazione di questo principio consente di limitare i potenziali danni causati da errori, compromissioni o comportamenti malevoli, e rende più semplice individuare attività anomale.

Sebbene strettamente collegati, i due principi operano su ambiti complementari: il *need-to-know* si concentra sul controllo dell'accesso ai dati e alle informazioni, mentre il *least privilege* si applica ai permessi operativi di utenti, applicazioni e processi. Insieme, costituiscono una base essenziale della sicurezza moderna, riducendo la superficie di attacco e favorendo una gestione granulare e responsabile delle risorse.

1.7 I tre pilastri della sicurezza

Il ciclo di gestione della sicurezza informatica è un processo continuo e iterativo che mira a garantire un livello di protezione adeguato e costante nel tempo. Anche in questo ambito sono state proposte diverse maniere per approcciare operativamente la sicurezza in maniera corretta. Uno di questi propone di strutturare le proprie attività secondo i tre pilastri della sicurezza[19].

Secondo questo approccio, prima di attivare le fasi operative, è essenziale una fase preliminare di *planning*, in cui si identificano i rischi, si definiscono politiche e requisiti di sicurezza, si stabiliscono priorità e si pianificano le procedure di risposta agli incidenti. Successivamente, il ciclo si articola in tre fasi principali:

1. *Avoidance*: implementazione di misure preventive per ridurre la probabilità e la superficie d'attacco, come firewall, segmentazione di rete, VPN, formazione degli utenti e politiche di aggiornamento. Questa fase non elimina completamente il rischio: anche i controlli

[18] **National Institute of Standards and Technology**: agenzia del governo degli Stati Uniti che pubblica linee guida e standard in materia di sicurezza informatica.

[19] Attenzione, esiste anche una versione, leggermente diversa, che propone quattro pilastri.

più robusti possono fallire o essere aggirati (anche se la defense in depth è implementata), rendendo necessario prevedere sempre misure di supporto, indicate dai pilastri successivi;

2. *Detection*: monitoraggio continuo del sistema per identificare tempestivamente anomalie, attività sospette o indicatori di compromissione (che potrebbero rivelare il fallimento dei sistemi di *avoidance*), tramite strumenti come sistemi IDPS, analisi dei log, monitoraggio del traffico di rete e tecniche di threat intelligence. Anche qui è possibile il fallimento: non tutte le minacce vengono rilevate immediatamente e alcune potrebbero rimanere latenti o mascherate;
3. *Investigation*: attività di analisi e risposta agli incidenti, come analisi forense, auditing e incident response, per comprenderne origine, dinamiche e impatti, ripristinare la normale operatività e adottare misure correttive. L'analisi forense è inoltre indispensabile in tutti quei casi in cui si configura una violazione delle leggi/norme/standard o se è necessario acquisire informazioni da usare in sede processuale. Non sempre l'indagine produce risultati completi o immediati, e possono emergere lacune informative o operative da colmare.

Ogni fase può rivelare criticità, rendendo necessaria una revisione delle misure adottate. Per questo il ciclo è ricorsivo: gli esiti dell'investigazione e della rilevazione alimentano un nuovo processo di pianificazione, migliorando continuamente procedure, controlli e strategie difensive. In altre parole, la sicurezza non è mai definitiva, ma richiede un aggiornamento dinamico per adattarsi all'evoluzione delle minacce e dei sistemi.

Acronimi

APT	Advanced Persistent Threat	19
BEC	Business Email Compromise	8
C.I.A.	Confidentiality, Integrity, Availability	5
CDB	Computer Data Breach	8
DDoS	Distributed Denial of Service	12
DNS	Domain Name System	12
DoS	Denial of Service	12
GDPR	General Data Protection Regulation	7
IoT	Internet of Things	7, 19
ISP	Internet Service Provider	10
KISS	Keep It Simple, Stupid	11
MFA	Multi-Factor Authentication	16
MITM	Man In The Middle	13
NIST	National Institute of Standards and Technology	23
RBAC	Role-Based Access Control	22